UNIDAD 2 · ACTIVIDAD PRÁCTICA

Sesión 10: Autenticación JWT y almacenamiento seguro

Implementación, verificación del backend y evidencias funcionales en Android

Estudiante	Jorge Armando Quispe Huaman
Proyecto	PharmaMobil · Kotlin Multiplatform
Rama	feature/auth-jwt-quispe
Fecha de verificación	14 de octubre de 2026
Alcance	Android. iOS omitido según el alcance indicado para esta entrega.

EVIDENCIAS REALES: ANDROID, POSTMAN Y LOGCAT

1. Objetivo y entorno de ejecución

Implementar un inicio de sesión contra **POST /api/v1/auth/login**, conservar el JWT de forma segura en Android, adjuntarlo automáticamente en solicitudes protegidas y controlar las respuestas **401** y **403**. También se comprobó el CRUD autenticado de productos.

Componente	Configuración verificada
Backend	PharmaSoft oficial con Spring Boot y JWT en http://localhost:8080
Base de datos	Oracle ejecutándose en Docker
Android	Emulador Pixel 8 Pro · API local mediante http://10.0.2.2:8080/api/v1/
Cliente HTTP	Ktor con ContentNegotiation, Logging y Auth Bearer
Seguridad local	JWT almacenado con EncryptedSharedPreferences

Implementación comprobada

✓ Modelo de dominio para credenciales, sesión, permisos y errores de autenticación.

✓ DTO de login y adaptación de la respuesta real de /auth/me.

✓ Ktor Bearer Auth con renovación desde el almacén local.

✓ Inicio de sesión, cierre de sesión y restauración automática de la sesión.

✓ Control visual por permisos: admin ve productos y clientes; almacen solo productos.

✓ Colección Postman con login, CRUD y casos esperados 401/403.

Hallazgo durante la validación

La respuesta real de **/auth/me** utiliza **empleadoNombre**. El DTO esperaba **nombreCompleto**, por lo que la primera restauración falló. Se corrigió el mapeo con compatibilidad para ambos nombres y se repitió la prueba satisfactoriamente.

2. Pruebas HTTP ejecutadas

Las solicitudes se ejecutaron contra el backend local activo. No se guardó ningún JWT en las evidencias; el encabezado se representa como **Authorization: ***.

Paso	Método	Endpoint	Esperado	Obtenido	Resultado
Servidor disponible	GET	/api/health	200	200	**OK**
Recurso sin JWT	GET	/api/v1/productos	401	401	**OK**
Login administrador	POST	/api/v1/auth/login	200	200	**OK**
Usuario autenticado	GET	/api/v1/auth/me	200	200	**OK**
Listar productos	GET	/api/v1/productos	200	200	**OK**
Crear producto	POST	/api/v1/productos	201	201	**OK**
Buscar producto	GET	/api/v1/productos/2	200	200	**OK**
Editar producto	PUT	/api/v1/productos/2	200	200	**OK**
Eliminar producto	DELETE	/api/v1/productos/2	204	204	**OK**
Permiso denegado	GET	/api/v1/clientes	403	403	**OK**

Registro automático de ejecución

```
$ Pruebas de PharmaSoft — ejecución local
[200] GET /api/health OK
[401] GET /api/v1/productos OK · sin JWT
[200] POST /api/v1/auth/login OK · admin
[200] GET /api/v1/productos OK · JWT válido
[201] POST /api/v1/productos OK · creado
[200] PUT /api/v1/productos/2 OK · editado
[204] DELETE /api/v1/productos/2 OK · baja lógica
[403] GET /api/v1/clientes OK · rol almacen
Authorization: ***
```

Interpretación: el backend exige autenticación, acepta el JWT del administrador, completa el CRUD y bloquea al usuario almacen cuando intenta consultar clientes.

3. Inicio de sesión en Android

La aplicación inicia en la pantalla de autenticación. Las credenciales se envían al backend; el JWT recibido se guarda en el almacenamiento cifrado de Android.

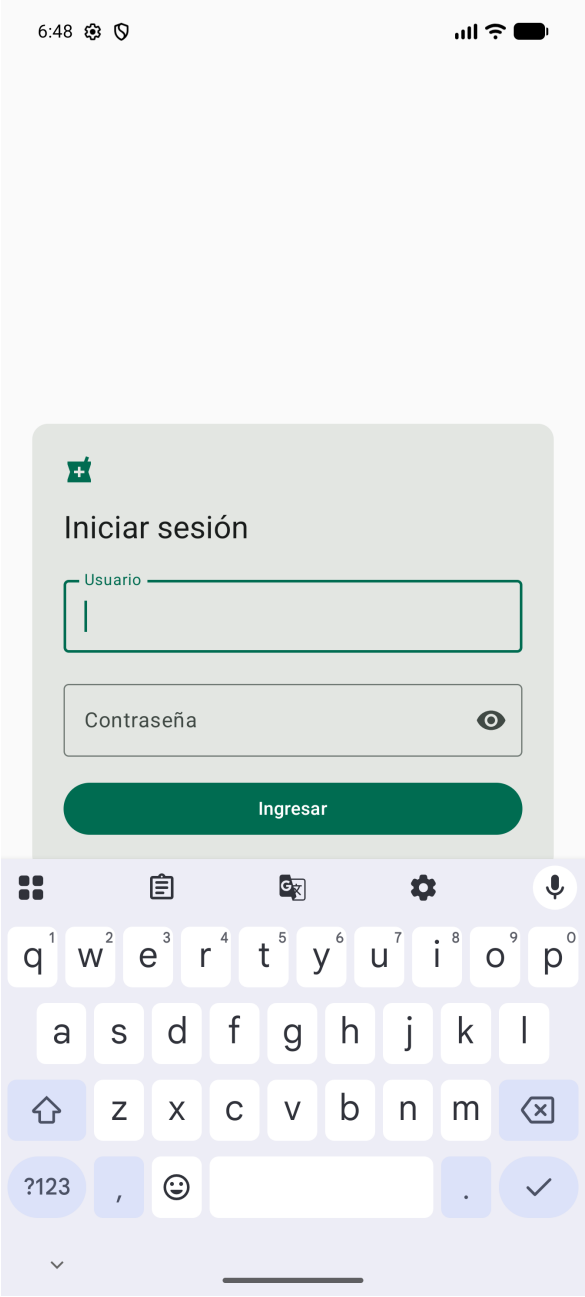


Figura 1. Pantalla inicial de autenticación en el emulador Pixel 8 Pro.

4. Acceso del administrador y recurso protegido

Con **admin / Admin123** el backend devuelve 200 y la aplicación presenta las opciones autorizadas. Al ingresar en Productos se ejecuta una solicitud autenticada con Bearer Token.



Figura 2. Inicio del administrador.



Figura 3. Pantalla protegida de Productos.

El administrador posee permisos de catálogo y clientes. La pantalla de Productos cargó correctamente mediante **GET /api/v1/productos** con respuesta 200.

5. Persistencia de sesión y permisos por rol

Se forzó el cierre del proceso de PharmaMobil y se volvió a abrir la aplicación. La sesión fue recuperada consultando **/auth/me**; no se solicitaron nuevamente las credenciales.



Figura 4. Sesión admin recuperada tras reiniciar.

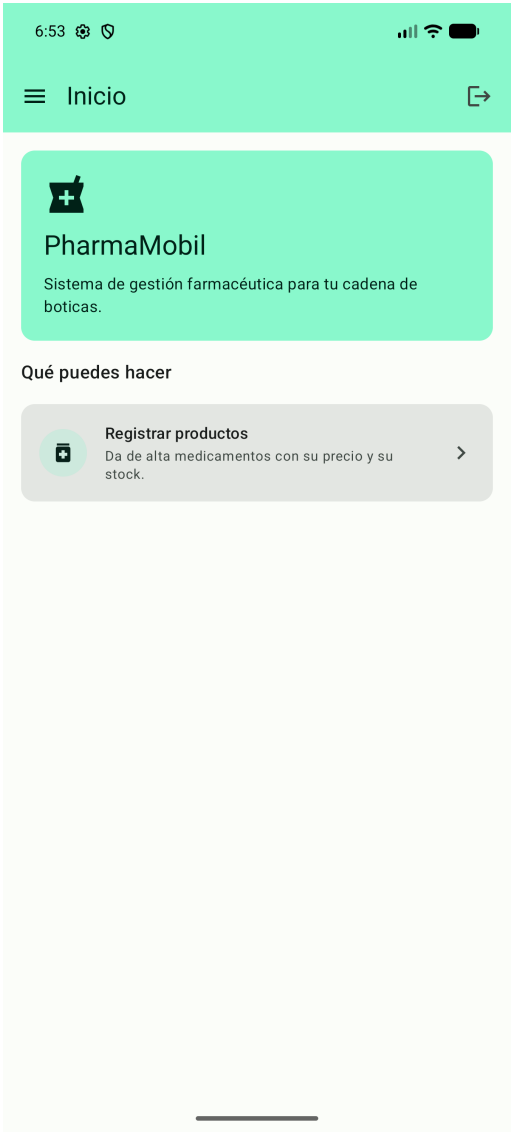
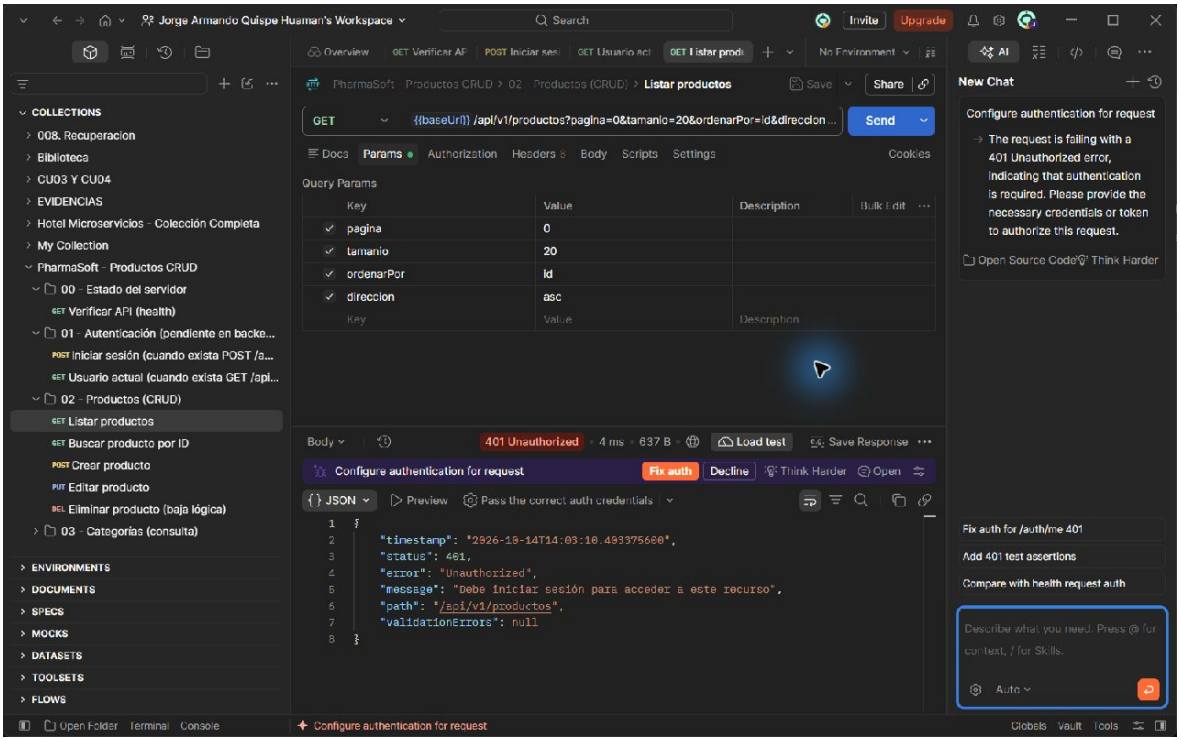


Figura 5. Usuario almacen: solo opción autorizada.

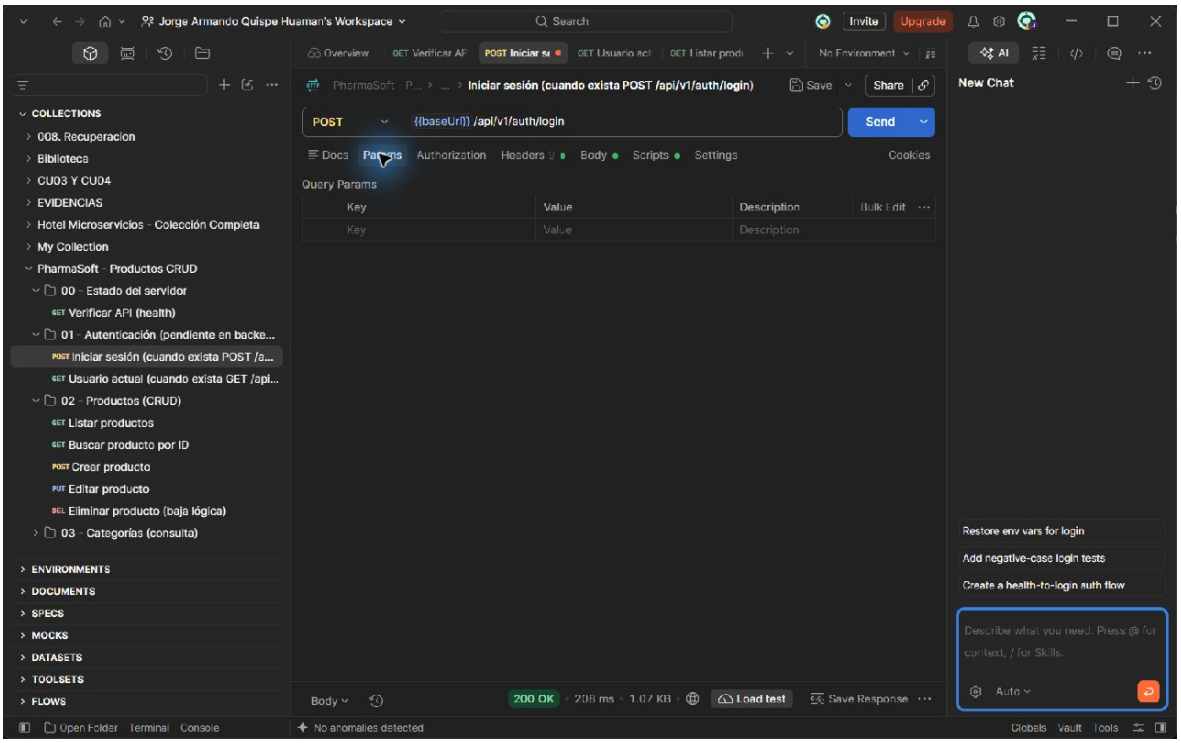
Usuario	Productos	Clientes	Comportamiento observado
admin	Permitido	Permitido	Acceso a ambas funciones
almacen	Permitido	Denegado	La opción Clientes no se muestra; el backend responde 403 si se solicita

6. Evidencias en Postman: JWT y permisos

Se ejecutaron estas solicitudes en la aplicación de escritorio Postman contra PharmaSoft local. Las capturas muestran el método, la URL, el código HTTP y la respuesta. El JWT no se muestra en el documento.

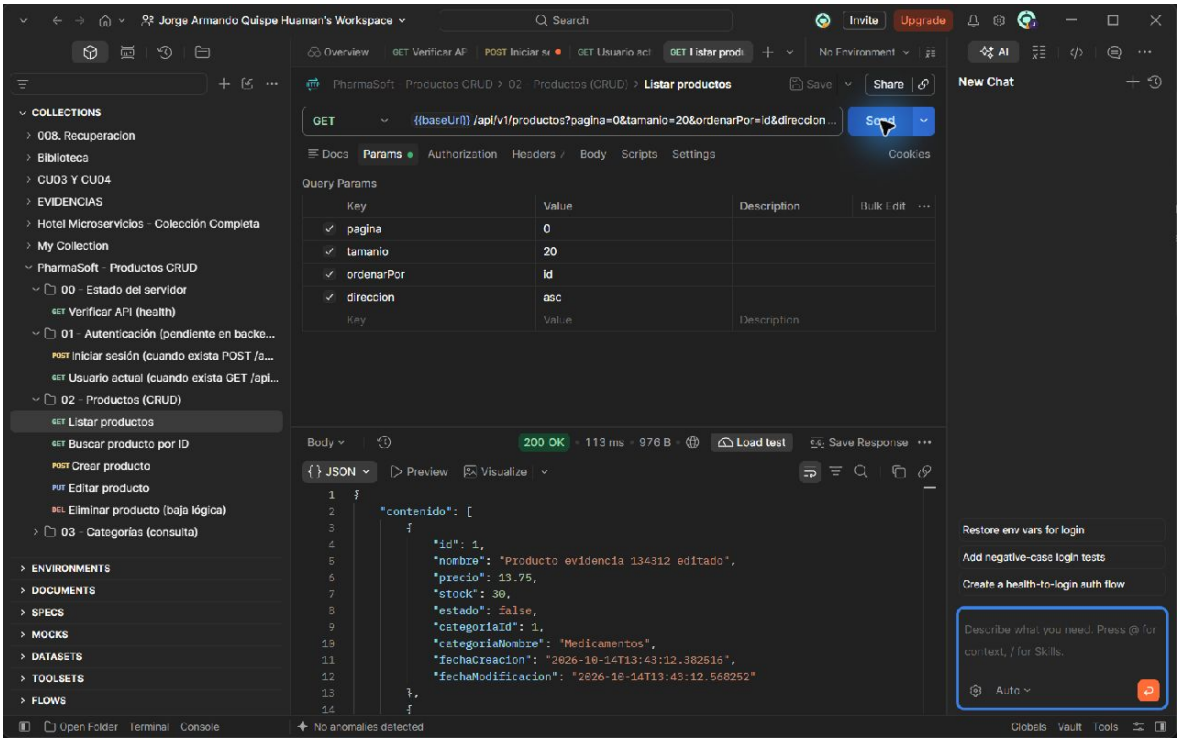


Sin iniciar sesión: GET Productos devuelve 401.

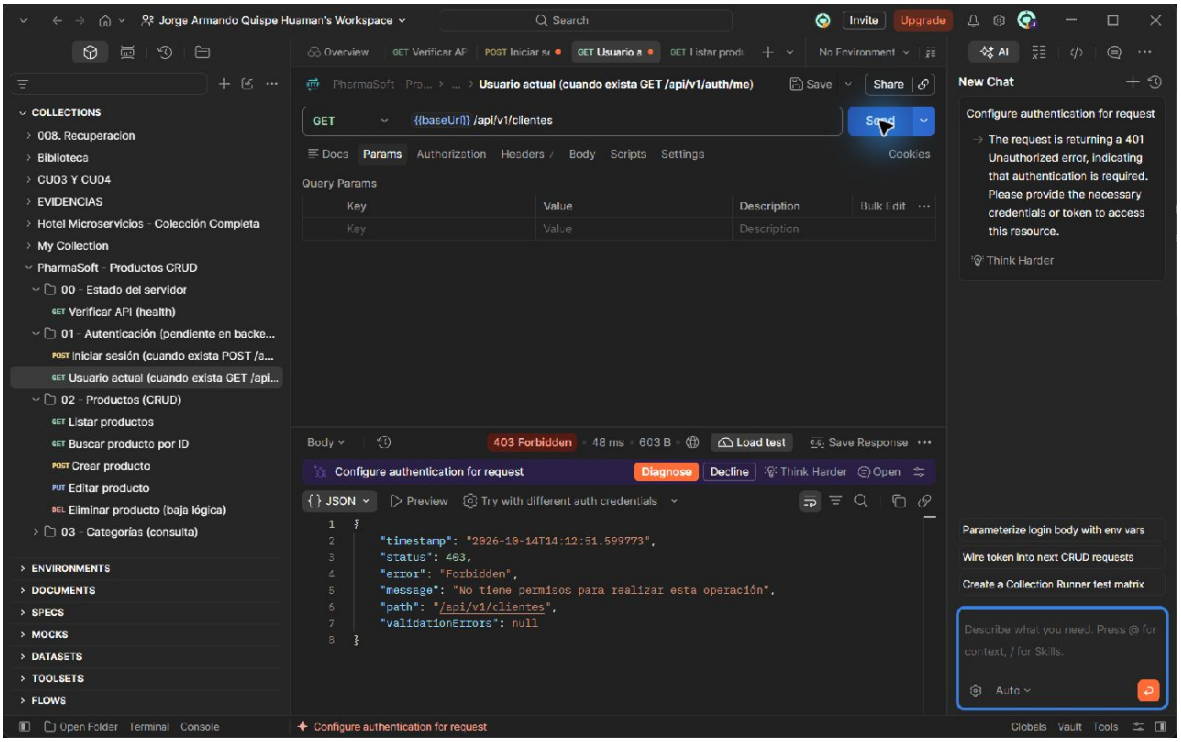


Login admin: POST /auth/login devuelve 200.

6. Postman: acceso permitido y denegado



Con JWT admin: GET Productos devuelve 200.

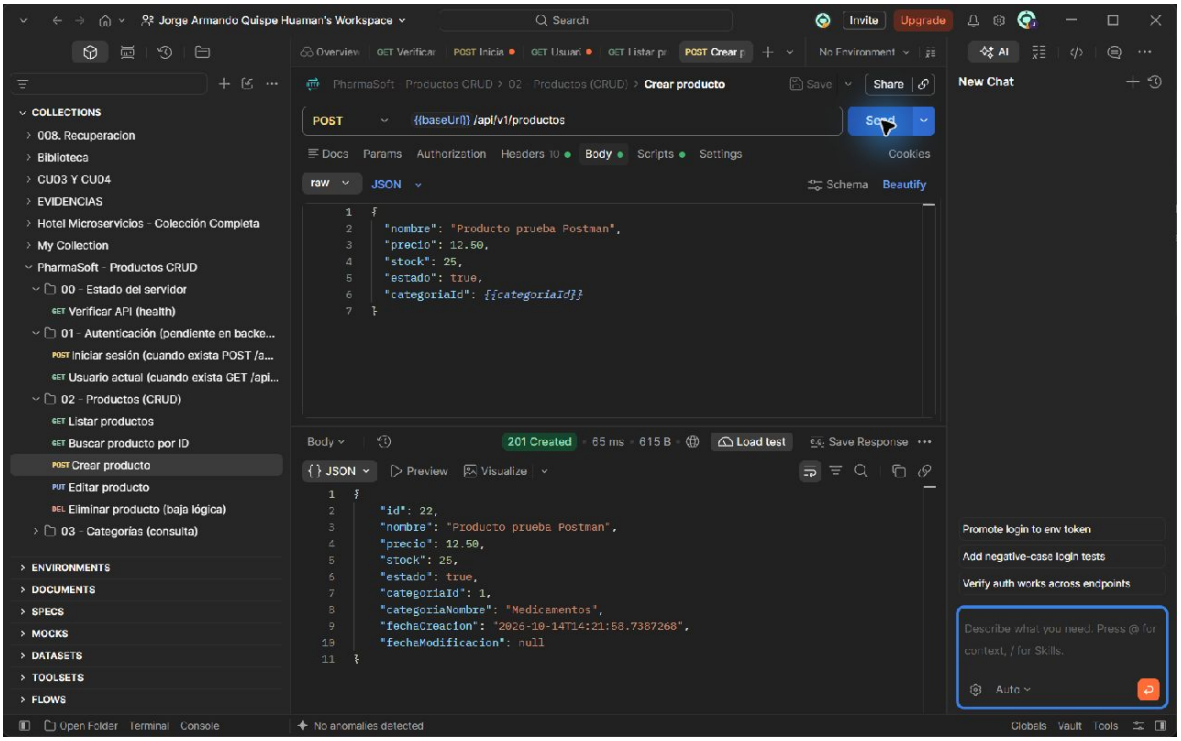


Con JWT almacen: GET Clientes devuelve 403.

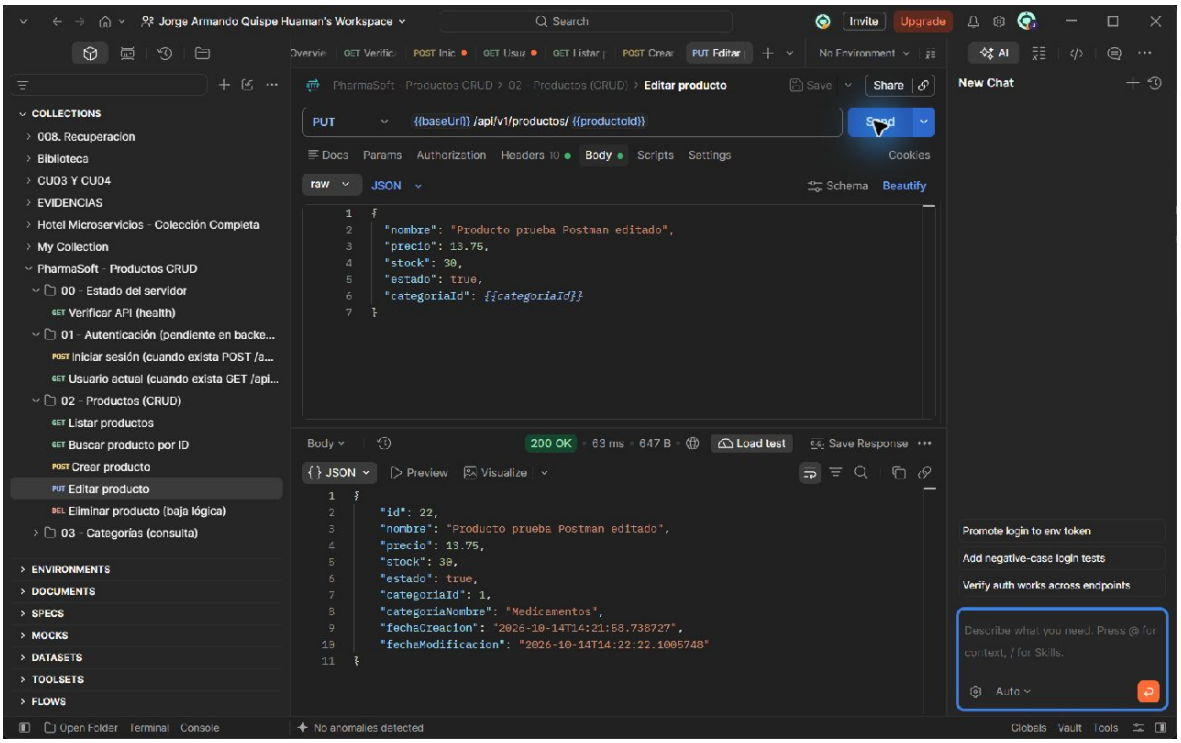
Android oculta las acciones no autorizadas para almacen. El 403 se provocó en Postman para comprobar la protección del backend y su mensaje de permisos.

7. Evidencias en Postman: CRUD autenticado

Con la sesión de administrador se creó el producto de prueba, se modificó y se dio de baja. La colección guarda el ID creado para usarlo en PUT y DELETE.

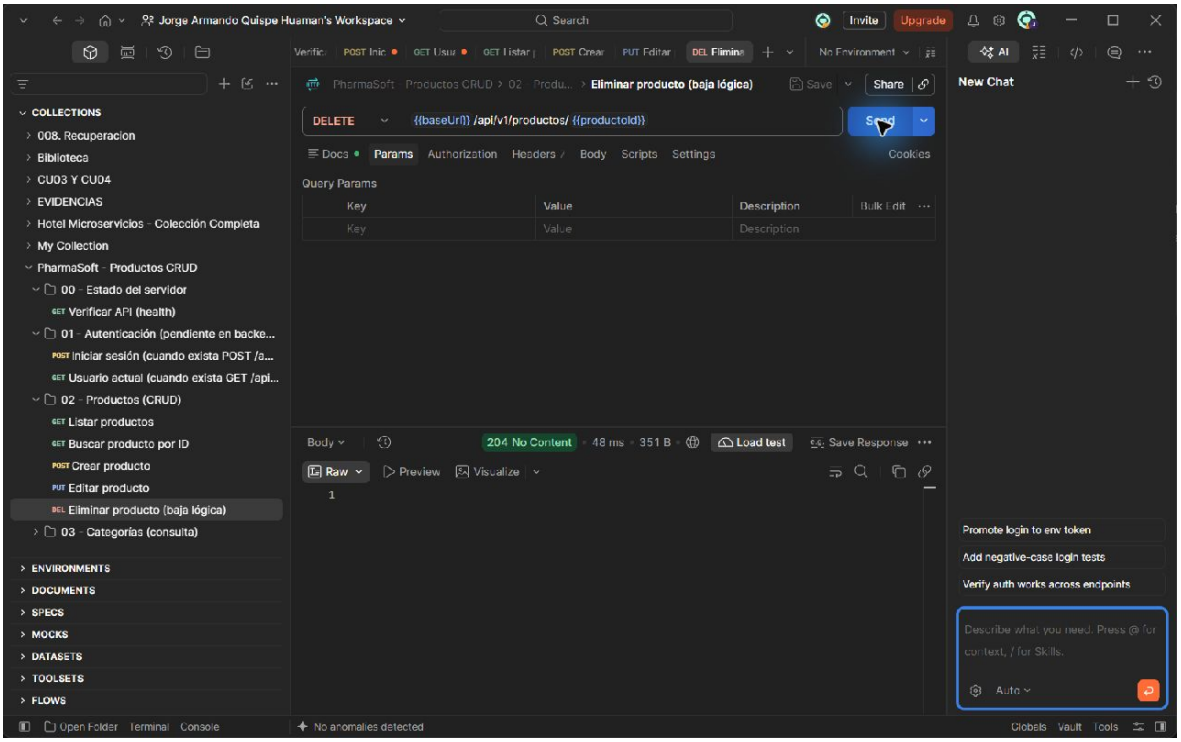


POST /productos: 201 Created, producto ID 22.



PUT /productos/22: 200 OK, precio y stock actualizados.

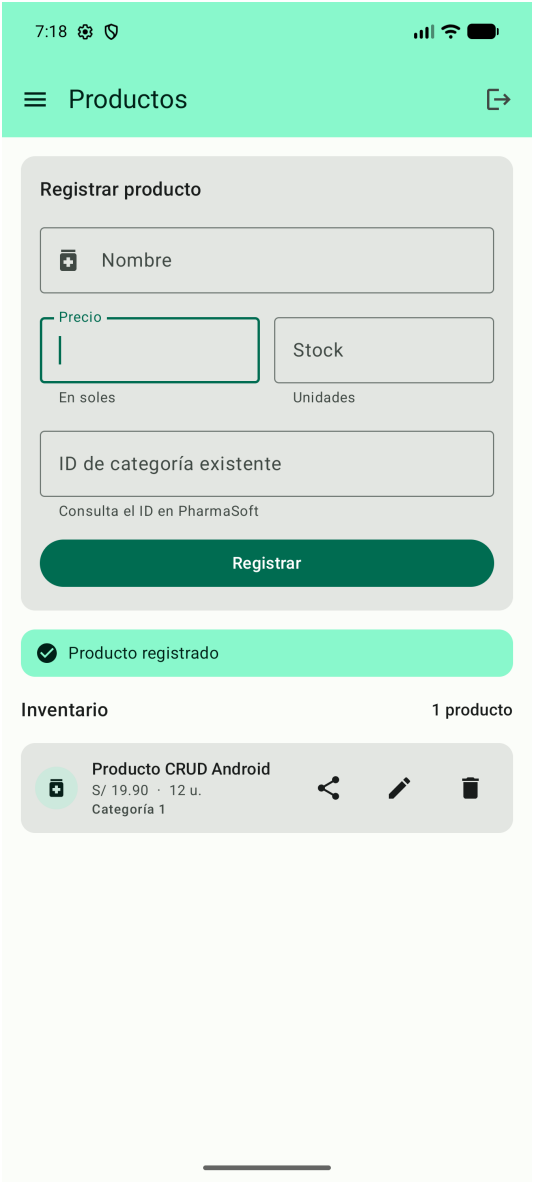
7. Postman: baja lógica



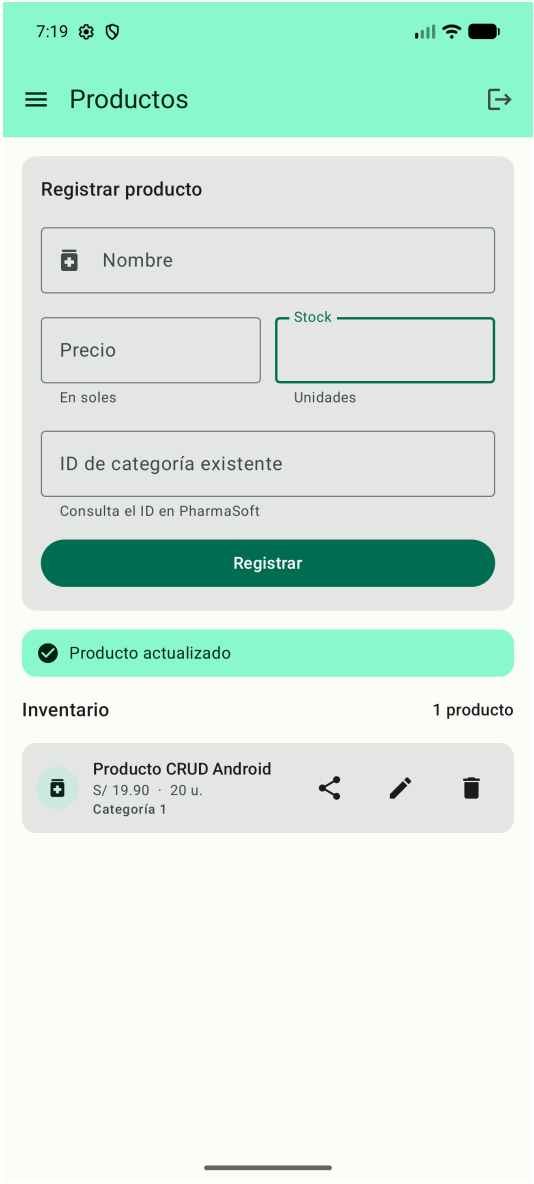
DELETE /productos/22: 204 No Content, baja lógica.

8. CRUD ejecutado desde Android

Se repitió el ciclo desde la app instalada en el emulador. El alta envió el campo obligatorio **estado=true**; después se modificó el stock de 12 a 20 y se dio de baja el mismo registro. Los mensajes verdes provienen de las respuestas exitosas del backend.

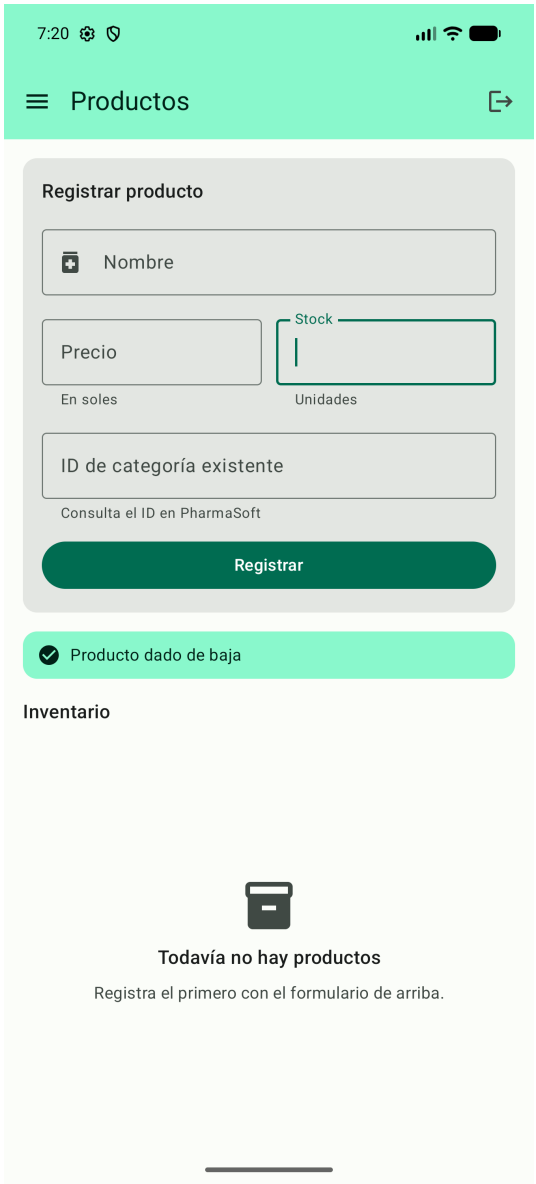


Producto registrado: precio S/ 19.90, stock 12.



Producto actualizado: stock 20.

8. CRUD en Android: baja y acceso del vendedor



Producto dado de baja: desaparece del inventario activo.



Vendedor: consulta el inventario sin formulario de registro.

La prueba del vendedor confirma el control visual del permiso de escritura. Para provocar un 403 reproducible se usó Postman con el usuario almacen y el recurso Clientes.

9. Logcat, compilación y repositorio

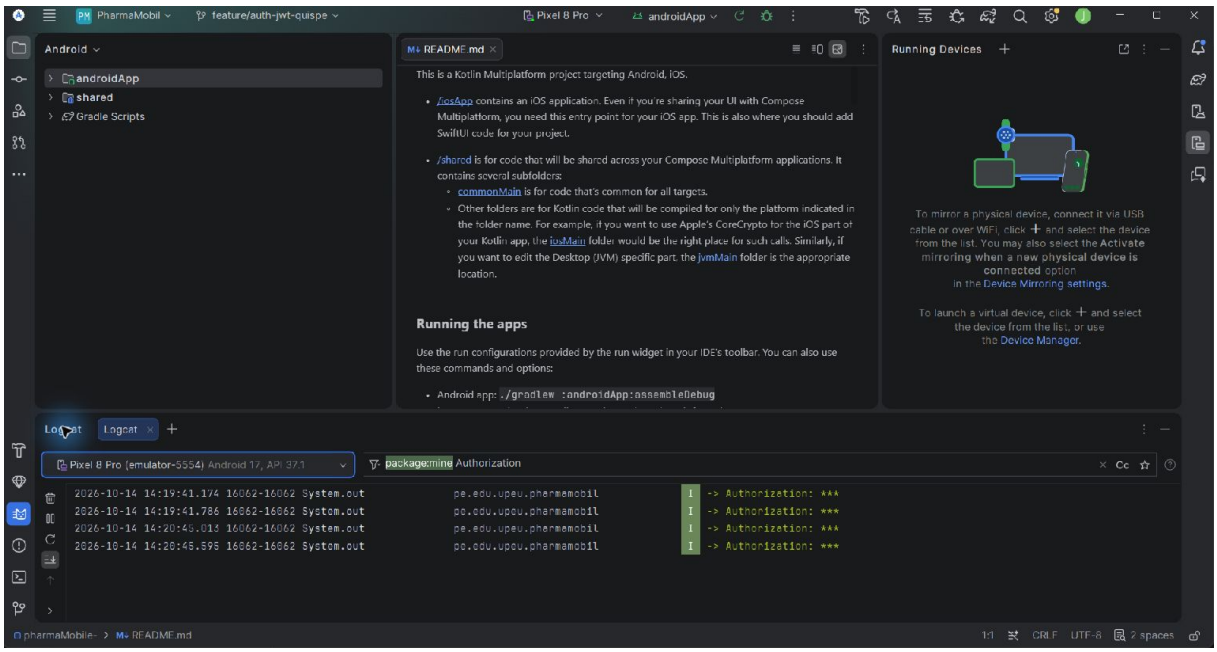
El cliente Ktor registra método, URL y estado para depuración. El valor del encabezado Authorization está completamente oculto.

```
10-14 18:48:44.525 12880 12880 I System.out: REQUEST:
http://10.0.2.2:8080/api/v1/productos?pagina=0&tamanio=20
10-14 18:48:44.526 12880 12880 I System.out: -> Authorization: ***
10-14 18:49:08.834 13640 13640 I System.out: REQUEST: http://10.0.2.2:8080/api/v1/auth/me
10-14 18:49:08.834 13640 13640 I System.out: -> Authorization: ***
10-14 18:52:46.611 14359 14359 I System.out: REQUEST: http://10.0.2.2:8080/api/v1/auth/me
10-14 18:52:46.611 14359 14359 I System.out: -> Authorization: ***
```

Transcripción de líneas reales de Logcat. Ningún JWT aparece en texto plano.

9. Captura de Logcat en Android Studio

El filtro **package:mine Authorization** muestra las solicitudes recientes de PharmaMobil. En todas, Android Studio registra **Authorization: ***** sin exponer el JWT.



Captura real de Android Studio Logcat con la cabecera saneada.

9. Compilación y repositorio

Verificación de compilación

Comando	Resultado
:shared:testAndroidHostTest	BUILD SUCCESSFUL
:androidApp:assembleDebug	APK debug generado correctamente
Instalación con ADB	Success en Pixel 8 Pro

Repositorio GitHub

Rama entregable: **feature/auth-jwt-quispe**
https://github.com/123456jor/pharmaMobile-/tree/feature/auth-jwt-quispe

Commit	Contenido
cd19a6f	Estado obligatorio enviado en el CRUD de Android; alta y edición verificadas
da27088	Corrección de restauración de sesión y colección Postman con 401/403
f9dbfe4	Login y control visual por permisos
1b35b3e	Repositorio de autenticación y sesión JWT
5594841	Ktor Bearer Auth, errores HTTP y logging sanitizado
d6af687	Almacenamiento cifrado del JWT en Android

10. Conclusiones

1	El backend protege correctamente los recursos: 401 sin token y 403 cuando el rol no posee el permiso requerido.
2	El administrador ejecutó el CRUD autenticado de productos tanto en Postman (201, 200 y 204) como en Android.
3	PharmaMobil guarda el JWT de forma cifrada, lo adjunta automáticamente y recupera la sesión al reiniciar la aplicación.
4	La interfaz aplica permisos: admin ve productos y clientes; almacen solo ve productos; vendedor consulta productos sin registrar nuevos.
5	El registro de red oculta Authorization como ***, evitando exponer el JWT en Logcat.
6	Durante las pruebas se corrigieron la restauración de sesión y el envío del campo estado al registrar productos desde Android; ambas correcciones se compilaron y verificaron.

Límite de esta verificación

El 403 está capturado en Postman y la interfaz oculta la acción prohibida; no se obtuvo una pantalla de error 403 dentro de Android. Tampoco se reprodujo en la app la expiración real del JWT y su redirección por 401. iOS quedó fuera del alcance solicitado.

ENTREGABLE CON EVIDENCIAS REALES Y ALCANCE DECLARADO